# Finding Open Service Ports

Discovering and understanding open ports is crucial in cybersecurity because they represent potential entry points for attackers. Open ports are like open doors on a network, and if not properly secured, they can be exploited to gain unauthorized access. Cybersecurity professionals use port scanning to identify these vulnerabilities and take steps to mitigate the risks.

## Scenario

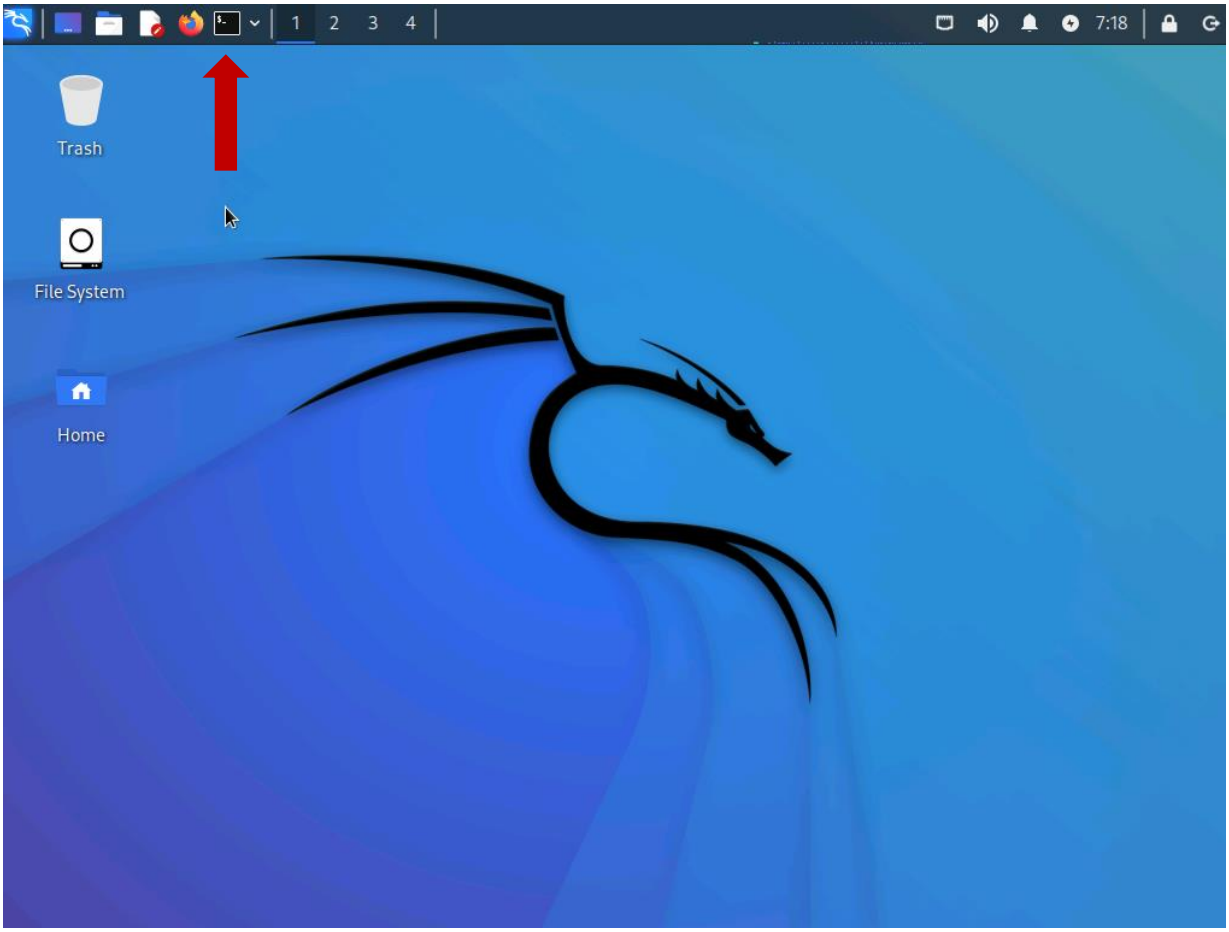
As a security team member of Structureality Inc, you are working to improve your organization's security stance. You are currently tasked with performing asset discovery and finding open service ports. Open service ports are a threat vector. If discovered, an open service port is a target for attack. Adversaries may be able to gain access to and control over systems through open service ports. By evaluating the status of ports on systems, especially internet-exposed systems, you can work to reduce the attack surface by closing unnecessary ports.

In this exercise, we will use a port scanner to detect open ports, enumerate service identities, and identify the operating system of targets. First, we will evaluate a border firewall from an outside location. Next, we will analyze the scan results from the Guest network. Finally, we will scrutinize the scan results of a server accessed from the Client network.

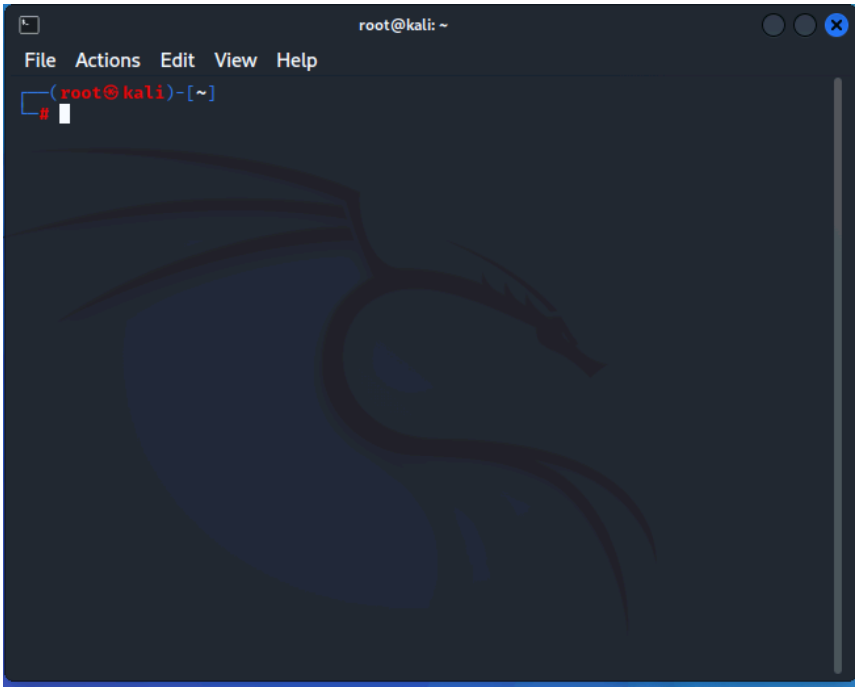
We will be working from a virtual machine named KALI hosting Kali Linux connected to the internal server subnet.

1. Connect to the KALI and sign in as **root** for root permissions.
    - You are purposely signing in as root for this lab to access all of nmap's capabilities and avoid permissions issues. If you are working from a non-root account, you must use **sudo su** to switch user context and elevate your Terminal window to root.
2. Open a Terminal window by selecting the **Terminal Emulator** from the Kali Linux toolbar (located at the top of the screen by default). This icon looks like a black computer screen with a cursor.

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.




- The Terminal window should already be elevated to use root privileges. Maximize the Terminal window. This optimizes the space for output and maximizes the amount of information that can be displayed at once. If needed, you can adjust the text size from the *Edit* menu of the Terminal window.




**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.

3. Enter the following command to perform a port scan of the top 100 common ports of the company's border router Internet facing interface at 203.0.113.1, using the SYN scan method, while identifying the services on open ports and the OS, disable host discovery, and saving the results into a file. *For all nmap parameters, capitalization is important.*
   - nmap 203.0.113.1 -F -sS -sV -O -Pn -oN border-scan.nmap

```
┌──(root㉿kali)-[~]
└─# nmap 203.0.113.1 -F -sS -sV -O -Pn -oN border-scan.nmap
```

   - **This nmap command will perform several operations against the target:**

     The "-F" parameter sets the scan to only test the top 100 popular ports.
     The "-sS" parameter sets the scan type to SYN scan. This is also the default scan type. The SYN scan is the most reliable scan option as it simulates the initial communication attempt from a valid client, while not completing the establishment of a full session. Therefore, the SYN scan has the best chance of determining the open state of TCP ports.
     The "-sV" parameter performs a version scan, which attempts to elicit the identity of services on open ports.
     The "-O" parameter attempts to identify the operating system.
     The "-Pn" parameter disables host discovery and assumes all IPs are actively in use.
     The "-oN" parameter saves the output of nmap to the specified filename (in addition to the screen display of the same).

   - This should take less than 30 seconds to complete. The output will be displayed to the screen as well as captured in a file.
   - You can view the standard syntax of nmap using **nmap** without any parameters. You can view the manual page for nmap using **man nmap**. You can also view the complete *Nmap Reference Guide* online at nmap.org/docs.html.
   - After the scan is complete below should be the results:

```
┌──(root㉿kali)-[~]
└─# nmap 203.0.113.1 -F -sS -sV -O -Pn -oN border-scan.nmap
Starting Nmap 7.93 ( https://nmap.org ) at 2025-05-16 07:26 PDT
Nmap scan report for 203.0.113.1
Host is up (0.0017s latency).
Not shown: 99 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
25/tcp open  smtp    Postfix smtpd
Warning: OSScan results may be unreliable because we could not find at least
1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): FreeBSD 11.X (92%)
OS CPE: cpe:/o:freebsd:freebsd:11.2
Aggressive OS guesses: FreeBSD 11.2-RELEASE (92%)
No exact OS matches for host (test conditions non-ideal).
Service Info: Host:  mailgw.structureality.com

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.76 seconds
```

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.

4. Enter the following command to display just the open port results:
   - grep open border-scan.nmap

```
┌──(root㉿kali)-[~]
└─# grep open border-scan.nmap
```

   - What port(s) are discovered as being open on this target is **Port# 25** which is Simple Mail Transfer Protocol (SMTP)

```
┌──(root㉿kali)-[~]
└─# grep open border-scan.nmap
25/tcp open  smtp    Postfix smtpd
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
```

*Open service ports represent a threat vector to an organization. Especially ports that are discoverable from the internet. Open ports for services like email (i.e., port 25/tcp for SMTP) and web (i.e., port 80/tcp HTTP) can be targeted for attacks. If those services have vulnerabilities, an adversary may be able to compromise the system and gain remote control. Generally, anything internet exposed needs to be hardened against any potential attack potential.*

5. Enter the following command to display just the OS detection results:
   - grep OS border-scan.nmap

```
┌──(root㉿kali)-[~]
└─# grep OS border-scan.nmap
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS CPE: cpe:/o:freebsd:freebsd:11.2
Aggressive OS guesses: FreeBSD 11.2-RELEASE (92%)
No exact OS matches for host (test conditions non-ideal).
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Being able to determine the OS of a target may allow an adversary to select a more effective exploit based on OS type and version. When possible, minimizing OS information made accessible to external entities would reduce this threat.

## Discover threat vectors from a guest network

In addition to the threats from the internet, you should also be concerned about threat sources closer to home. A guest network may be a nice benefit to offer visitors, but if not properly configured, it could expose company resources to attack. Change the network location of your Kali workstation to perform an analysis of the attack surface from the guest network.

We will now obtain a new IP address in the server subnet.

1. Open up a new terminal in Kali Linux
2. Enter **dhclient -r && dhclient**

```
┌──(root㉿kali)-[~]
└─# dhclient -r && dhclient
```

*This command will release the previously assigned IP address from the internet subnet and obtain a new IP address in the server subnet.*

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.

3. Enter **ip a s eth0**.
   *This command displays the IP configuration information for just the eth0 interface.*

```
┌──(root㉿kali)-[~]
└─# ip a s eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:15:5d:01:ca:4a brd ff:ff:ff:ff:ff:ff
    inet 192.168.16.6/24 brd 192.168.16.255 scope global dynamic eth0
       valid_lft 6950sec preferred_lft 6950sec
    inet6 fe80::e04d:540e:5e85:361c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

4. Enter the following command to perform a port scan against the guest network's gateway device at 192.168.16.254 of the top 100 common ports, using the SYN scan method, while identifying the services on open ports and the OS, and saving the results into a file.
   - nmap 192.168.16.254 -F -sS -sV -O -oN guest-scan.nmap

```
┌──(root㉿kali)-[~]
└─# nmap 192.168.16.254 -F -sS -sV -O -oN guest-scan.nmap
Starting Nmap 7.93 ( https://nmap.org ) at 2025-05-18 11:30 PDT
Nmap scan report for 192.168.16.254
Host is up (0.0017s latency).
Not shown: 95 filtered tcp ports (no-response)
PORT     STATE SERVICE   VERSION
25/tcp   open  smtp      Postfix smtpd
53/tcp   open  domain    Unbound 1.17.1
80/tcp   open  http      OPNsense
443/tcp  open  ssl/https OPNsense
8000/tcp open  http-alt  OPNsense
```

```
3 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at
 https://nmap.org/cgi-bin/submit.cgi?new-service :
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port80-TCP:V=7.93%I=7%D=5/18%Time=682A2739%P=x86_64-pc-linux-gnu%r(GetR
SF:equest,94,"HTTP/1\.0\x20301\x20Moved\x20Permanently\r\nLocation:\x20htt
SF:ps:///\r\nContent-Length:\x200\r\nConnection:\x20close\r\nDate:\x20Sun,
SF:\x2018\x20May\x202025\x2018:30:17\x20GMT\r\nServer:\x20OPNsense\r\n\r\n
SF:")%r(HTTPOptions,94,"HTTP/1\.0\x20301\x20Moved\x20Permanently\r\nLocati
SF:on:\x20https:///\r\nContent-Length:\x200\r\nConnection:\x20close\r\nDat
SF:e:\x20Sun,\x2018\x20May\x202025\x2018:30:17\x20GMT\r\nServer:\x20OPNsen
SF:se\r\n\r\n")%r(RTSPRequest,1ED,"HTTP/1\.0\x20400\x20Bad\x20Request\r\nC
SF:ontent-Type:\x20text/html\r\nContent-Length:\x20345\r\nConnection:\x20c
SF:lose\r\nDate:\x20Sun,\x2018\x20May\x202025\x2018:30:17\x20GMT\r\nServer
SF::\x20OPNsense\r\n\r\n<\?xml\x20version=\"1\.0\"\x20encoding=\"iso-8859-
SF:1\"\?>\n<!DOCTYPE\x20html\x20PUBLIC\x20\"-//W3C//DTD\x20XHTML\x201\.0\x
SF:20Transitional//EN\"\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\"http://www\
SF:.w3\.org/TR/xhtml1/DTD/xhtml1-transitional\.dtd\">\n<html\x20xmlns=\"ht
SF:tp://www\.w3\.org/1999/xhtml\"\x20xml:lang=\"en\"\x20lang=\"en\">\n\x20
SF:<head>\n\x20\x20<title>400\x20Bad\x20Request</title>\n\x20</head>\n\x20
SF:<body>\n\x20\x20<h1>400\x20Bad\x20Request</h1>\n\x20</body>\n</html>\n"
SF:)%r(FourOhFourRequest,B3,"HTTP/1\.0\x20301\x20Moved\x20Permanently\r\nL
SF:ocation:\x20https:///nice%20ports%2C/Trinity\.txt\.bak\r\nContent-Lengt
SF:h:\x200\r\nConnection:\x20close\r\nDate:\x20Sun,\x2018\x20May\x202025\x
SF:2018:30:22\x20GMT\r\nServer:\x20OPNsense\r\n\r\n")%r(GenericLines,1ED,"
SF:HTTP/1\.0\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/html\r\nCon
SF:tent-Length:\x20345\r\nConnection:\x20close\r\nDate:\x20Sun,\x2018\x20M
SF:ay\x202025\x2018:30:23\x20GMT\r\nServer:\x20OPNsense\r\n\r\n<\?xml\x20v
SF:ersion=\"1\.0\"\x20encoding=\"iso-8859-1\"\?>\n<!DOCTYPE\x20html\x20PUB
SF:LIC\x20\"-//W3C//DTD\x20XHTML\x201\.0\x20Transitional//EN\"\n\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20\"http://www\.w3\.org/TR/xhtml1/DTD/xhtml1-tr
SF:ansitional\.dtd\">\n<html\x20xmlns=\"http://www\.w3\.org/1999/xhtml\"\x
SF:20xml:lang=\"en\"\x20lang=\"en\">\n\x20<head>\n\x20\x20<title>400\x20Ba
SF:d\x20Request</title>\n\x20</head>\n\x20<body>\n\x20\x20<h1>400\x20Bad\x
SF:20Request</h1>\n\x20</body>\n</html>\n");
```

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.

```
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port443-TCP:V=7.93%T=SSL%I=7%D=5/18%Time=682A2744%P=x86_64-pc-linux-gnu
SF:%r(GetRequest,D95,"HTTP/1\.0\x20200\x20OK\r\nSet-Cookie:\x20PHPSESSID=6
SF:7016f2cf2bade0cb68e16ef18bf8c01;\x20path=/;\x20secure;\x20HttpOnly\r\nS
SF:et-Cookie:\x20PHPSESSID=67016f2cf2bade0cb68e16ef18bf8c01;\x20path=/;\x2
SF:0secure;\x20HttpOnly\r\nSet-Cookie:\x20cookie_test=6603e3db80024d1037ed
SF:f40cd8874e1a;\x20expires=Sun,\x2018-May-2025\x2019:30:23\x20GMT;\x20Max
SF:-Age=3600;\x20path=/;\x20secure;\x20HttpOnly\r\nExpires:\x20Thu,\x2019\
SF:x20Nov\x201981\x2008:52:00\x20GMT\r\nCache-Control:\x20no-store,\x20no-
SF:cache,\x20must-revalidate\r\nPragma:\x20no-cache\r\nContent-Security-Po
SF:licy:\x20default-src\x20'self';\x20script-src\x20'self'\x20'unsafe-inli
SF:ne'\x20'unsafe-eval';\x20style-src\x20'self'\x20'unsafe-inline'\x20'uns
SF:afe-eval';\r\nX-Frame-Options:\x20SAMEORIGIN\r\nX-Content-Type-Options:
SF:\x20nosniff\r\nX-XSS-Protection:\x201;\x20mode=block\r\nReferrer-Policy
SF::\x20same-origin\r\nContent-type:\x20text/html;\x20charset=UTF-8\r\nCon
SF:tent-Length:\x202643\r\nConnection:\x20close\r\nDate:\x20Sun,\x2018\x20
SF:May\x202025\x2018:30:24\x20GMT\r\nServer:\x20OPNsense\r\n\r\n<!doctype\
SF:x20html>\n<html\x20lang=\"en\"\x20class=\"no-js\">\n\x20\x20<head>\n\x2
SF:0\x20\x20\x20<meta\x20")%r(HTTPOptions,394,"HTTP/1\.0\x20403\x20Forbidd
SF:en\r\nSet-Cookie:\x20PHPSESSID=c6962d67fddc4c69e60a031d5ba13c9b;\x20pat
SF:h=/;\x20secure;\x20HttpOnly\r\nExpires:\x20Thu,\x2019\x20Nov\x201981\x2
SF:008:52:00\x20GMT\r\nCache-Control:\x20no-store,\x20no-cache,\x20must-re
SF:validate\r\nPragma:\x20no-cache\r\nContent-type:\x20text/html;\x20chars
SF:et=UTF-8\r\nContent-Length:\x20563\r\nConnection:\x20close\r\nDate:\x20
SF:Sun,\x2018\x20May\x202025\x2018:30:28\x20GMT\r\nServer:\x20OPNsense\r\n
SF:\r\n<html><head><title>CSRF\x20check\x20failed</title>\n\x20\x20\x20\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20<script>\n\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20\x20\x20\x20\x20\$\(\x20document\x20\)\.ready\(function\(\)
SF:\x20{\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\$\.ajaxSetup\({\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\
SF:x20\x20\x20\x20\x20\x20\x20'beforeSend':\x20function\(xhr\)\x20{\n\x20\
SF:x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:\x20\x20\x20xhr\.setRequestHeader\(\"X-CSRFToken\",\x20\"QVNnb3BNYlQ4bl
SF:dTeS9WbVEzUlFJQT09\"\x20\);\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20\x20}\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x
SF:20\x20\x20\x20\x20\x20\x20}\);\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x2
SF:0\x20\x20\x20\x20}\);\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:</script>\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20</head>\n\x2
SF:0\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20<b
SF:ody>\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20\x20
SF:x20\x20<p>CSRF\x20check\x20failed\.\x20Your\x20form\x20session\x20may\x
```

```
==============NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)==============
SF-Port8000-TCP:V=7.93%I=7%D=5/18%Time=682A2739%P=x86_64-pc-linux-gnu%r(Ge
SF:nericLines,1ED,"HTTP/1\.0\x20400\x20Bad\x20Request\r\nContent-Type:\x20
SF:text/html\r\nContent-Length:\x20345\r\nConnection:\x20close\r\nDate:\x2
SF:0Sun,\x2018\x20May\x202025\x2018:30:17\x20GMT\r\nServer:\x20OPNsense\r\
SF:n\r\n<\?xml\x20version=\"1\.0\"\x20encoding=\"iso-8859-1\"\?>\n<!DOCTYP
SF:E\x20html\x20PUBLIC\x20\"-//W3C//DTD\x20XHTML\x201\.0\x20Transitional//
SF:EN\"\n\x20\x20\x20\x20\x20\x20\x20\x20\x20\"http://www\.w3\.org/TR/xhtm
SF:l1/DTD/xhtml1-transitional\.dtd\">\n<html\x20xmlns=\"http://www\.w3\.or
SF:g/1999/xhtml\"\x20xml:lang=\"en\"\x20lang=\"en\">\n\x20<head>\n\x20\x20
SF:<title>400\x20Bad\x20Request</title>\n\x20</head>\n\x20<body>\n\x20\x20
SF:<h1>400\x20Bad\x20Request</h1>\n\x20</body>\n</html>\n")%r(GetRequest,3
SF:1B7,"HTTP/1\.0\x20200\x20OK\r\nContent-Type:\x20text/html\r\nLast-Modif
SF:ied:\x20Sun,\x2018\x20May\x202025\x2018:16:40\x20GMT\r\nContent-Length:
SF:\x2012421\r\nExpires:\x20Mon,\x2019\x20May\x202025\x2000:30:17\x20GMT\r
SF:\nCache-Control:\x20no-store,\x20no-cache,\x20must-revalidate,\x20post-
SF:check=0,\x20pre-check=0\r\nConnection:\x20close\r\nDate:\x20Sun,\x2018\
SF:x20May\x202025\x2018:30:17\x20GMT\r\nServer:\x20OPNsense\r\n\r\n<!docty
SF:pe\x20html>\n<html>\n\n<head>\n\n\x20\x20\x20\x20<meta\x20charset=\"UTF
SF:-8\"\x20/>\n\x20\x20\x20\x20<meta\x20http-equiv=\"X-UA-Compatible\"\x20
SF:content=\"IE=edge,chrome=1\">\n\n\x20\x20\x20\x20<meta\x20name=\"robots
SF:\"\x20content=\"index,\x20follow,\x20noodp,\x20noydir\"\x20/>\n\x20\x20
SF:\x20\x20<meta\x20name=\"keywords\"\x20content=\"\"\x20/>\n\x20\x20\x20\
SF:x20<meta\x20name=\"description\"\x20content=\"\"\x20/>\n\x20\x20\x20\x2
SF:0<meta\x20name=\"copyright\"\x20content=\"\"\x20/>\n\x20\x20\x20\x20<me
SF:ta\x20name=\"viewport\"\x20content=\"width=device-width,\x20initial-sca
SF:le=1,\x20maximum-scale=1,\x20user-scalable=no\"\x20/>\n\n\x20\x20\x20\x
SF:20<title></title>\n\x20\x20\x20\x20<!--\x20Bootstrap\x20-->\n\x20\x20\x
SF:20\x20<link\x20href=\"css/bootstrap\.min\.css\"\x20rel=\"stylesheet\">\
SF:n\x20\x20\x20\x20<link\x20href=\"css/signin\.css\"\x20rel=\"stylesheet\
SF:">\n\n\x20\x20\x20\x20<!--\x20stat");
MAC Address: 00:15:5D:01:86:03 (Microsoft)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: FreeBSD 11.X
OS CPE: cpe:/o:freebsd:freebsd:11.2
```

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.

5. Enter command to display **just the open port results**:
   - grep open guest-scan.nmap

```
┌──(root㉿kali)-[~]
└─# grep open guest-scan.nmap
25/tcp   open  smtp      Postfix smtpd
53/tcp   open  domain    Unbound 1.17.1
80/tcp   open  http      OPNsense
443/tcp  open  ssl/https OPNsense
8000/tcp open  http-alt  OPNsense
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
```

*The service detected on ports 80, 443, and 8000 is the firewall. These ports can be used to access the firewall's management interface. It is not a secure deployment if a guest network member can access the management interface of the company firewall. These ports should be closed on the guest network. Keep in mind, that some ports should remain open to support valid communications, such as DNS (53), web (80/443), and email (25/465/587 (SMTP), 110/995 (POP3), 143/993 (IMAP)).*

6. Enter command to display just the OS detection results:
   - grep OS guest-scan.nmap

```
┌──(root㉿kali)-[~]
└─# grep OS guest-scan.nmap
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS CPE: cpe:/o:freebsd:freebsd:11.2
OS details: FreeBSD 11.2-RELEASE
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

*Being able to determine the OS of a target may allow an adversary to select a more effective exploit based on OS type and version. When possible, minimizing OS information made accessible to external entities would reduce this threat.*

## Discover the attack surface of the internal network

Guest network members are usually temporary visitors. But, what about the long-term risk of internal entities - both computers and users? Scanning internal network systems for open service ports can reveal aspects of the internal attack surface. In this exercise, you will position your Kali workstation in the Client subnet but scan a system in the Server subnet.

1. Open Terminal and enter command: **dhclient -r && dhclient**.
2. Enter **ip a s eth0**.
3. Enter **nmap 10.1.16.2 -F -sS -sV -O -oN server-scan.nmap**

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.

```
┌──(root㉿kali)-[~]
└─# ip a s eth0
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc mq state UP group default qlen 1000
    link/ether 00:15:5d:01:ca:4a brd ff:ff:ff:ff:ff:ff
    inet 10.1.24.66/24 brd 10.1.24.255 scope global dynamic eth0
       valid_lft 691174sec preferred_lft 691174sec
    inet6 fe80::e04d:540e:5e85:361c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever

┌──(root㉿kali)-[~]
└─# nmap 10.1.16.2 -F -sS -sV -O -oN server-scan.nmap
Starting Nmap 7.93 ( https://nmap.org ) at 2025-05-18 11:43 PDT
Nmap scan report for MS10.ad.structureality.com (10.1.16.2)
Host is up (0.0026s latency).
Not shown: 88 filtered tcp ports (no-response)
PORT     STATE SERVICE      VERSION
25/tcp   open  smtp         hMailServer smtpd
80/tcp   open  http         Microsoft IIS httpd 10.0
111/tcp  open  rpcbind      2-4 (RPC #100000)
135/tcp  open  msrpc        Microsoft Windows RPC
139/tcp  open  netbios-ssn  Microsoft Windows netbios-ssn
143/tcp  open  imap         hMailServer imapd
443/tcp  open  ssl/http     Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
445/tcp  open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: structureality)
587/tcp  open  smtp         hMailServer smtpd
2049/tcp open  mountd       1-3 (RPC #100005)
3306/tcp open  mysql        MySQL 5.5.5-10.11.3-MariaDB
5357/tcp open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Microsoft Windows 2016
OS CPE: cpe:/o:microsoft:windows_server_2016
OS details: Microsoft Windows Server 2016
Service Info: Hosts: mail.structureality.com, MS10; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.96 seconds
```

4. Enter **grep open server-scan.nmap**

```
┌──(root㉿kali)-[~]
└─# grep open server-scan.nmap
25/tcp   open  smtp         hMailServer smtpd
80/tcp   open  http         Microsoft IIS httpd 10.0
111/tcp  open  rpcbind      2-4 (RPC #100000)
135/tcp  open  msrpc        Microsoft Windows RPC
139/tcp  open  netbios-ssn  Microsoft Windows netbios-ssn
143/tcp  open  imap         hMailServer imapd
443/tcp  open  ssl/http     Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
445/tcp  open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: structureality)
587/tcp  open  smtp         hMailServer smtpd
2049/tcp open  mountd       1-3 (RPC #100005)
3306/tcp open  mysql        MySQL 5.5.5-10.11.3-MariaDB
5357/tcp open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
```

*The number of open service ports on this server is significant. While many of these services may be present for a valid reason, that needs to be verified. Any necessary service should be configured to use encrypted communications, even internally. Also, notice that all of these service ports are discoverable as open (and service versions elicited) because there is no firewall separating the Client and Server networks. This is evidence of a lack of effective network segmentation. It needs to be recognized that internal systems represent a real threat vector. An insider can cause just as much harm as an external intruder.*

5. Enter **grep OS server-scan.nmap**

```
┌──(root㉿kali)-[~]
└─# grep OS server-scan.nmap
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
OS CPE: cpe:/o:microsoft:windows_server_2016
OS details: Microsoft Windows Server 2016
Service Info: Hosts: mail.structureality.com, MS10; OS: Windows; CPE: cpe:/o:microsoft:windows
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.

*The Windows Server 2016 OS has reached its EOL (End of Life) on Jan 11, 2022. This means it is no longer considered an actively developed and supported OS. However, it may continue to receive security updates through Jan 12, 2027. At that date, it will be labeled EOSL (End of Service Life). This system should be slated for replacement before it reaches the EOSL date.*

**Disclaimer:** This documentation is part of a structured research and development initiative designed to support cybersecurity training and operational readiness. All scenarios represent simulated threat environments intended to enhance proficiency in identifying vulnerabilities, deploying defensive controls, and ensuring system resilience. Tools used are industry-recognized and deployed in a lawful lab setting for educational purposes. The exercises align with NIST, ISO, and CIS standards and are grounded in real-world use cases. No unauthorized testing or activities are conducted, and all procedures strictly adhere to ethical hacking principles. This training environment serves as a foundational step in workforce development and infrastructure protection.